

HiveForce Labs

THREAT ADVISORY



ATTACK REPORT

From npm to GitHub: TeamPCP's May 2026 Escalation Reaches the Source Code Platform

Date of Publication

May 22, 2026

Admiralty Code

A1

TA Number

TA2026140

Summary

First Seen: Late 2025

Attack Commenced: May 2026

Targeted Platforms: GitHub (internal repositories, GitHub Actions, VS Code Marketplace), npm registry, PyPI registry, OpenVSX, developer endpoints (macOS, Linux)

Threat Actor: TeamPCP (aka PCPcat, ShellForce, DeadCatx3, CipherForce, Persy_PCP, UNC6780)

Targeted Industries: Software Development, AI/ML, Cloud Computing, CI/CD Pipelines, Data Analytics/Visualization, Enterprise Automation, Source Code Hosting Platforms

Malware: Mini Shai-Hulud Worm, Credential-stealing VS Code extension (GitHub breach vector)

Attack: May 2026 marked the most intense stretch of TeamPCP's ongoing supply chain campaign, with the financially motivated group escalating from package-level poisoning to ecosystem-wide worm propagation and ultimately a direct breach of GitHub itself. First documented in late 2025 as a cloud-native exploitation crew, the group pivoted in March 2026 to a cascading supply chain campaign spanning Trivy, Checkmarx KICS, LiteLLM, and dozens of npm packages, before unleashing the Mini Shai-Hulud worm in May across the npm and PyPI ecosystems and a follow-on @antv wave that brought the cumulative footprint to over 1,000 malicious versions across 500+ unique packages. TeamPCP then open-sourced the worm code with a \$1,000 underground bounty, spawning copycat variants within days, and on May 20 exfiltrated roughly 3,800 internal GitHub repositories through a poisoned VS Code extension installed by an employee. With affiliate extortion channels dormant throughout the month, the group has clearly shifted to monetizing supply chain credential theft directly, signaling a sustained, platform-level threat to the developer ecosystem well into the second half of 2026.



Attack Timeline

Launches **supply chain campaign** via Trivy compromise; cascades through KICS, LiteLLM, and Telnx.

Mini Shai-Hulud worm hits @tanstack and 170+ npm/PyPI packages with valid SLSA L3 provenance.

Breaches GitHub directly, exfiltrates ~3,800 internal repositories via poisoned VS Code extension.

July 2025

Mar 19, 2026

March 30, 2026

May 11 & 19, 2026

May 19, 2026

May 20, 2026

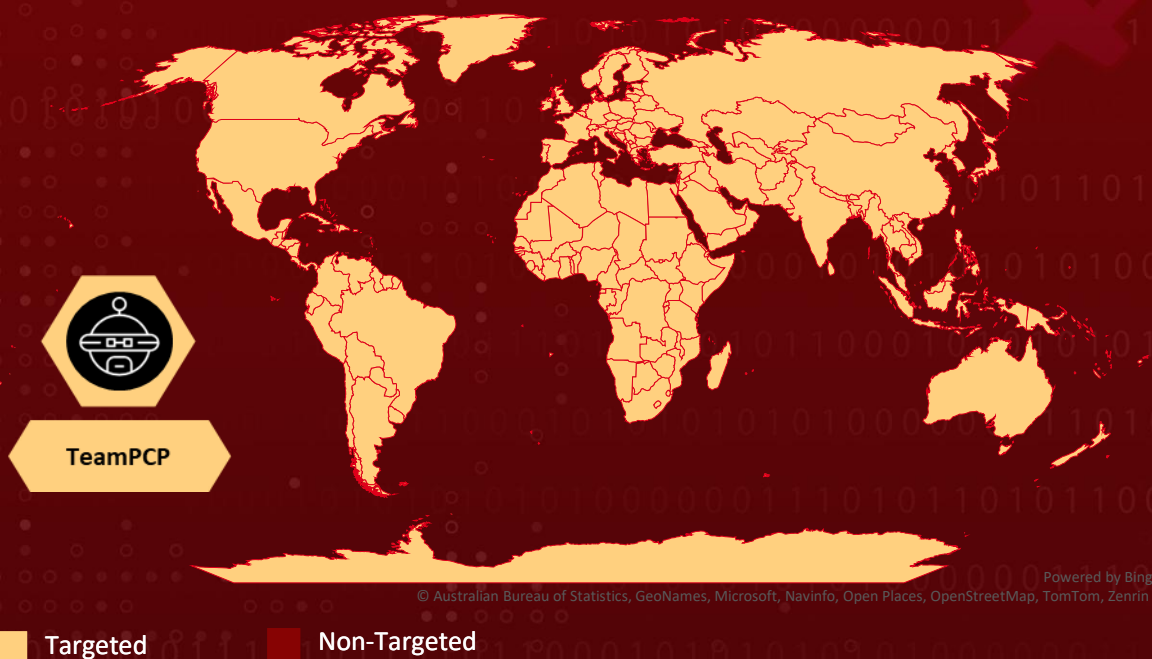
Emerges as cloud-native exploitation crew targeting exposed Docker APIs and Kubernetes clusters.

Vect ransomware begins publishing victims tied to TeamPCP-stolen credentials.

@antv wave compromises 300+ packages; **Open-sources Shai-Hulud worm code** with \$1,000 bounty.



Attack Regions



Attack Details

#1

May 2026 marked the most intense stretch of [TeamPCP](#)'s ongoing supply chain campaign, with the financially motivated threat cluster escalating from package-level poisoning to ecosystem-wide worm propagation and ultimately a direct breach of GitHub itself. The group continued its run of compromises against widely deployed security and developer tooling early in the month before shifting into a sustained, multi-wave assault on the open-source ecosystem that culminated in the compromise of GitHub's own internal environment.

#2

First documented in late 2025 as a cloud-native exploitation crew targeting exposed Docker APIs and Kubernetes clusters, TeamPCP escalated sharply in March 2026 with a cascading supply chain campaign that ran from Aqua Security's Trivy through Checkmarx KICS, LiteLLM, Telnix, and dozens of npm packages, a chain of compromises monetized in part through a partnership with the [Vect ransomware](#) group, whose data leak site published victims and data attributed to TeamPCP-stolen credentials. By May, the group's reach had grown large enough that a rival worm, [PCPJack](#), emerged in the wild specifically to evict TeamPCP infections and steal credentials from already-compromised hosts.

#3

The mid-month centerpiece was the [Mini Shai-Hulud worm](#), which propagated across the npm and PyPI ecosystems by abusing GitHub Actions misconfigurations and produced malicious packages signed with valid SLSA Build Level 3 provenance. A second wave on May 19 extended the campaign through a hijacked maintainer account in the [@antv](#) ecosystem, bringing the cumulative footprint to over 1,000 malicious versions across 500+ unique packages.

#4

TeamPCP then dramatically lowered the barrier for copycats by releasing the source code of its Shai-Hulud worm, encouraging other threat actors to use it in supply chain attacks in exchange for monetary rewards. The release included a modular framework comprising loaders, secrets harvesters, a dispatcher, exfiltrators, and mutators, along with a \$1,000 underground bounty for the largest supply chain attack mounted with the code. Copycat variants emerged within days, including one that converts victims into a DDoS botnet, leaving defenders facing a growing population of strains with different C2 endpoints and payloads that share enough DNA to be dangerous but not enough to share detection signatures.

#5

The campaign's most consequential event came on May 20, when GitHub disclosed a direct breach of its own environment. TeamPCP exfiltrated roughly 3,800 internal repositories through a poisoned VS Code extension installed by an employee, gaining credentials with permissions sufficient to clone the company's internal repositories. The attack followed a now-familiar pattern: once installed, a malicious VS Code extension has full access to source code, system keychain credentials, SSH keys, cloud keys, GitHub authentication tokens, and shell history, enough for a single extension to silently harvest and exfiltrate every secret on a developer's machine. An X account linked to the group publicly taunted GitHub over the delayed disclosure, claiming the platform "knew for hours" before notifying affected parties.

#6

Throughout May, TeamPCP's affiliated extortion channels remained dormant, with no new postings observed across the month, reinforcing the assessment that the group is now monetizing primarily through supply chain credential theft rather than affiliate ransomware. The shift in operating model, combined with the public release of the worm's source code and a direct compromise of GitHub, signals that TeamPCP has moved from opportunistic package poisoning to a sustained, platform-level threat against the developer ecosystem, with downstream effects likely to compound well into the second half of 2026.

Recommendations



Audit and Restrict VS Code Extensions Across Developer Endpoints: Inventory every VS Code, OpenVSX, and JetBrains extension installed across developer machines and CI environments, and enforce a vetted allowlist of trusted publishers. The strongest publicly identified candidate for the GitHub breach vector is a trojanized version of Nx Console (nrwl.angular-console) v18.95.0, published to the VS Code Marketplace on May 18, 2026 and live for roughly 11 minutes before being pulled, any developer who installed or updated Nx Console during that window should be treated as compromised. Block sideloaded or unsigned extensions at the endpoint and require security review before any new extension is approved.



Isolate and Image Endpoints Before Rotating Credentials: Treat any suspected compromised developer machine as a forensic asset before initiating cleanup. GitHub detected and contained the device compromise, removed the malicious extension version, and isolated the endpoint before beginning incident response — that sequence matters. Production AWS keys, kubeconfigs, Vault tokens, GitHub PATs with repo and workflow scope, npm publishing tokens, signing certificates, and SSH keys for production hosts are routinely present on developer endpoints, so isolate first, image second, and only then rotate.



Rotate All GitHub-Adjacent Secrets with Broad Scope: Assume that GitHub Personal Access Tokens, deploy keys, OAuth app credentials, GitHub Actions secrets, and CI/CD tokens accessible from any compromised endpoint have been exfiltrated. Prioritize rotation of tokens with repo, workflow, and organization-level scopes first, then move to fine-grained tokens. Audit recent token usage logs for unfamiliar IP addresses, unusual API calls, and bulk repository clone activity in the days surrounding the suspected compromise.



Tighten Trust Boundaries on OIDC and Trusted Publishing: OIDC removes the long-lived publishing token, but only on the assumption that the workflow producing the short-lived token is itself trustworthy. TeamPCP has repeatedly broken that assumption by compromising the workflow itself. Restrict OIDC trust policies to specific protected branches, workflows, and environments, and require manual approval gates for publishes to package registries. Pin all third-party GitHub Actions to full commit SHAs and audit recently used actions for unexpected changes.



Treat Developer Devices as Production Infrastructure: Developer endpoints have effectively become the new perimeter, a single compromised IDE extension can expose source code, signing keys, cloud credentials, and the keys to an entire engineering organization's CI/CD pipeline. Enforce EDR coverage, MDM enrollment, and least-privilege access on every developer machine that holds production credentials.



Potential MITRE ATT&CK TTPs

Tactic	Technique	Sub-technique
Initial Access	<u>T1195</u> : Supply Chain Compromise	<u>T1195.002</u> : Compromise Software Supply Chain
		<u>T1195.001</u> : Compromise Software Dependencies and Development Tools
	<u>T1078</u> : Valid Accounts	
Execution	<u>T1204</u> : User Execution	<u>T1204.002</u> : Malicious File
	<u>T1059</u> : Command and Scripting Interpreter	<u>T1059.007</u> : JavaScript
	<u>T1106</u> : Native API	
Persistence	<u>T1176</u> : Browser Extensions	
	<u>T1543</u> : Create or Modify System Process	<u>T1543.001</u> : Launch Agent
		<u>T1543.002</u> : Systemd Service
	<u>T1546</u> : Event Triggered Execution	
Defense Evasion	<u>T1027</u> : Obfuscated Files or Information	
	<u>T1036</u> : Masquerading	<u>T1036.005</u> : Match Legitimate Name or Location
	<u>T1070</u> : Indicator Removal	<u>T1070.006</u> : Timestamp
	<u>T1656</u> : Impersonation	
Credential Access	<u>T1552</u> : Unsecured Credentials	<u>T1552.001</u> : Credentials In Files
		<u>T1552.004</u> : Private Keys
	<u>T1555</u> : Credentials from Password Stores	<u>T1555.005</u> : Password Managers
	<u>T1528</u> : Steal Application Access Token	
	<u>T1539</u> : Steal Web Session Cookie	



Tactic	Technique	Sub-technique
Discovery	<u>T1526</u> : Cloud Service Discovery	
	<u>T1083</u> : File and Directory Discovery	
Collection	<u>T1005</u> : Data from Local System	
	<u>T1213</u> : Data from Information Repositories	<u>T1213.003</u> : Code Repositories
Lateral Movement	<u>T1072</u> : Software Deployment Tools	
Command & Control	<u>T1071</u> : Application Layer Protocol	<u>T1071.001</u> : Web Protocols
	<u>T1102</u> : Web Service	<u>T1102.002</u> : Bidirectional Communication
	<u>T1132</u> : Data Encoding	
Exfiltration	<u>T1567</u> : Exfiltration Over Web Service	<u>T1567.001</u> : Exfiltration to Code Repository
	<u>T1041</u> : Exfiltration Over C2 Channel	
Impact	<u>T1657</u> : Financial Theft	
	<u>T1485</u> : Data Destruction	

✂ Indicators of Compromise (IOCs)

TYPE	VALUE
Domains	check.git-service[.]com, t.m-kosche[.]com
URLs	hxxps[:]//check[.]git-service[.]com/rope.pyz, hxxps[:]//t[.]m-kosche[.]com[:]443/api/public/otel/v1/traces, hxxps[:]//api[.]github[.]com/search/commits?q=firedalazer
SHA256	1a4afce34918bdc74ae3f31edaafffaa0ee074d83618f53edfd8813792 7340b8, b0cefb66b953e5184b6adb3035e9e267335ac5eabfe1848e07834777 b9397b74, e7347d90653efc565f03733a95e9209d78f9cfa81e31ff2b2dd9d48d7 5a4b8b1, 43f2b001846c4966073ebffa5be8f15e491a1e7d32bbd805d57406ff5 40e0dd9, 069ac1dc7f7649b76bc72a11ac700f373804bfd81dab7e561157b703 999f44ce
SHA1	558b09d7ad0d1660e2a0fb8a06da81a6f42e06d2, ba642fe2c7c65e42dd7f6444b83023dc6827e08c, acfc3f957a63b4cde93ff645f2b6bf26a8ed1bbf, 9d88f040c44b5f4d5f9db15ff89310776c168e99, 7cb42f57561c321ecb09b4552802ae0ac55b3a7a
File paths	~/.local/share/kitty/cat.py, ~/Library/LaunchAgents/com.user.kitty-monitor.plist, /tmp/kitty-*, /var/tmp/.gh_update_state, /tmp/managed.pyz, /tmp/rope-*.pyz, ~/.cache/.sys-update-check, ~/.cache/.sys-update-check-k8s, .claude/settings.json, .claude/setup.mjs, .vscode/tasks.json, .vscode/setup.mjs, .github/workflows/codeql.yml
LaunchAgent	pgsql-monitor.service, com.user.kitty-monitor.plist
Malicious VS Code extension	nrwl.angular-console@18.95.0
Malicious PyPI package	durabledtask==1.4.1, durabledtask==1.4.2, durabledtask==1.4.3



References

<https://www.stepsecurity.io/blog/nx-console-vs-code-extension-compromised>

<https://github.com/nrwl/nx-console/security/advisories/GHSA-c9j4-9m59-847w>

<https://github.blog/security/investigating-unauthorized-access-to-githubs-internal-repositories/>

<https://hivepro.com/threat-advisory/teampcp-automated-supply-chain-from-trivy-to-litellm-in-a-multi-ecosystem-breach/>

<https://hivepro.com/threat-advisory/mini-shai-hulud-npm-supply-chain-worm-tanstack-and-multi-ecosystem-compromise/>

<https://hivepro.com/threat-advisory/vect-ransomware-flawed-encryption-turns-raas-locker-into-irreversible-file-wiper/>

<https://hivepro.com/threat-advisory/pcpjacks-hijacks-vulnerable-servers-with-worm-like-cloud-propagation-tactics/>



What Next?

At Hive Pro, it is our mission to detect the most likely threats to your organization and to help you prevent them from happening.

Book a Demo of HivePro.

REPORT GENERATED ON

May 22, 2026 • 10:00 AM

© 2026 All Rights are Reserved by Hive Pro



More at www.hivepro.com